

Table of Contents

Status da revisão: Rascunho de tradução assistida por máquina. Requer revisão humana de terminologia, significado, links, formatação e atualidade técnica antes de ser marcado como edição final.

SÉRIE PRÁTICA DE CIBERSEGURANÇA, PRIVACIDADE E CONFORMIDADE

ISO/IEC 27001:2022 & ISO/IEC 27002:2022

****IsMS prático, risco, auditoria, controles e ferramentas de código aberto**

Um manual de trabalho para gerentes, analistas juniores, estudantes, profissionais em transição de carreira, auditores internos e equipes de segurança

**** Alberto (Al) Leiva****

Primeira edição • Julho de 2026

• todos os 93 controles do Anexo A • risco • declaração de aplicabilidade • auditoria • certificação • provas • ferramentas • laboratórios • preparação para a carreira

Publicação e Aviso de Uso

Autor: Alberto (Al) Leiva

Edição: Primeira Edição, Julho 2026

Este manual educacional independente não é uma publicação ISO, consultoria jurídica, decisão de certificação, relatório de auditoria ou substituto para os padrões licenciados ISO/IEC. As publicações ISO têm direitos autorais. As descrições de controle e de cláusula aqui são resumos originais; use as normas oficiais para requisitos exatos e orientação.

ISO desenvolve padrões, mas não certifica as organizações. A certificação é opcional e é realizada por organismos de certificação. Verifique o status de acreditação, escopo, locais, versão e certificado antes de confiar em uma reivindicação de certificação.

Uso ético e autorizado

Use ferramentas técnicas apenas em sistemas, aplicativos, redes, contas em nuvem, repositórios e dados que você possui ou estão especificamente autorizados por escrito para avaliar. Use dados sintéticos e sistemas isolados em laboratórios.

Prefácio

- Uma introdução prática à gestão da segurança da informação e à garantia baseada em provas.*

ISO/IEC 27001 é um padrão de requisitos para estabelecer, implementar, manter e melhorar continuamente um sistema de gestão da segurança da informação. Utiliza o gerenciamento de risco para preservar a confidencialidade, integridade e disponibilidade de forma que se encaixe na organização. ISO/IEC 27002 fornece orientações de controlo detalhadas, mas não é em si uma norma de certificação.

As edições de base atuais são ISO/IEC 27001:2022 e ISO/IEC 27002:2022. ISO/IEC 27001:2022 A alteração 1:2024 acrescenta explicitamente a consideração das alterações climáticas ao contexto organizacional e observa que as partes interessadas podem ter requisitos relacionados com o clima. A emenda não significa que cada organização deve criar um programa climático; deve fazer e apoiar uma determinação fundamentada de relevância dentro do contexto ISMS.

Um ISMS bem sucedido não é uma pasta de políticas. Trata-se de um sistema de gestão funcional: líderes estabelecem direção, os proprietários de risco tomam decisões de tratamento informadas, as equipes operam controles, os testes de auditoria interna o sistema, os resultados das revisões de gestão e as ações corretivas evitam a recorrência.

Como usar este manual

Os gerentes devem começar com os capítulos 1–5 e 18–23.

Os analistas júnior devem estudar cláusulas, temas do Anexo A, testes de evidências, ferramentas, laboratório e preparação de entrevista.

Os auditores internos devem centrar-se em critérios objetivos, independência, populações completas, amostragem, resultados, medidas corretivas e acompanhamento.

As organizações que buscam certificação devem confirmar as expectativas de certificação, alteração, escopo de certificação e credenciamento com profissionais competentes.

Conteúdo: Este documento contém um campo nativo da tabela de conteúdos do Word e um guia de capítulo verificado. Depois de editar, clique com o botão direito do mouse no conteúdo e escolha o Campo de Atualização e, em seguida, atualize a tabela inteira.

Sumário

[Comunicação de publicação e uso \[2\]](#)

[Uso ética e autorizada \[2\]](#)

[Prefácio \[3\]](#)

[Como usar este manual \[4\]](#)

[Sumário \[4\]](#)

[1. ISO/IEC 27001 e 27002 Fundações \[7\]](#)

[2. Âmbito de aplicação do ISMS e partes interessadas \[8\]](#)

[3. Avaliação dos riscos e tratamento dos riscos \[9\]](#)

[4. Declaração de aplicabilidade \[10\]](#)

5. Documentação e provas [11]
6. Cláusula 4 — Contexto da organização [12]
7. Cláusula 5 — Liderança [13]
8. Cláusula 6 — Planejamento [14]
9. Cláusula 7 — Apoio [15]
10. Cláusula 8 — Operação [16]
11. Cláusula 9 — Avaliação do desempenho [17]
12. Cláusula 10 — Melhoria [18]
13. Anexo A 5 Controles organizacionais [19]
- 14) Anexo A 6 Pessoas que controlam [22]
15. Anexo A 7 Controles físicos [23]
16. Anexo A 8 Controles tecnológicos [24]
17. Controles de execução com ISO/IEC 27002 [26]
18. Testes Métricos e de Controlo [27]
19. Auditoria Interna [28]
20. Revisão de gestão e ação corretiva [29]
21. Preparação da certificação [30]
22. Ferramentas de Código Aberto [31]
 - 22.1 Assistente CISO [31]
 - 22.2 Comunidade SimpleRisk [31]
 - 22.3 Wazuh [31]
 - 22,4 osquery [32]
 - 22.5 OpenSCAP [32]
 - 22.6 Greenbone Community Edition [32]
 - 22,7 Nmap [32]
 - 22.8 Trivy [32]
 - 22,9 OWASP ZAP [33]
 - 22.10 Keycloak [33]

22.11 DefectDojo [33]

22.12 AIDE [33]

22.13 Lynis [33]

22.14 Agente de política aberta [33]

23. Manual do SGSI para gerentes [35]

24. Guia de carreira do analista júnior [36]

24,1 Trabalho júnior típico [36]

24,2 Valor dos empregadores de competências [37]

25. Laboratório Fictício e Portfólio [38]

26. Plano de aprendizagem de trinta dias [39]

27. Preparação da entrevista [40]

27.1 O que é um ISMS? [40]

27,2 ISO 27001 versus 27002? [40]

27.3 O que é o SoA? [40]

27.4 Todos os controles do anexo A são obrigatórios? [40]

27.5 Como se testa um controlo? [40]

27.6 O que é uma não conformidade? [40]

27.7 O que mudou em 2024? [40]

27.8 O que pode um analista júnior concluir com segurança? [40]

27.9 Perguntas ao empregador [40]

28. Modelos, Glossário, Índice e Referências [42]

28.1 Registro mínimo de risco [42]

28.2 Papel de trabalho para teste de controle [42]

28.3 Glossário [42]

28,4 Índice de assunto [43]

28.5 Referências oficiais [43]

1. Fundamentos da ISO/IEC 27001 e da ISO/IEC 27002

Edições atuais, finalidade, relação entre as normas e limitações importantes.

Figura 1. Ciclo de melhoria contínua do ISMS



Reconstrução localizada programática para revisão — ISO/IEC 27001/27002

O contexto e o risco orientam o planejamento, a implementação, a avaliação e a melhoria.

Figura 1. Ciclo de melhoria contínua do SGSI

Documento	Função	Certificação
ISO/IEC 27001:2022	Requisitos normativos do SGSI, incluindo os controles de referência do Anexo A	As organizações podem obter certificação com base nessa norma
ISO/IEC 27001:2022/Amd 1:2024	Alterações relacionadas à ação climática que afetam o contexto e a consideração das partes interessadas	Aplicada em conjunto com a norma-base
ISO/IEC 27002:2022	Orientações para a implementação de controles de segurança da informação	Não é uma norma de certificação
ISO/IEC 27005:2022	Orientações para a gestão de riscos de segurança da informação	Orientação de apoio; não é a norma de certificação ISO/IEC 27001
- As cláusulas 4 a 10 contêm requisitos que a organização deve atender para demonstrar conformidade. - O Anexo A apresenta 93 controles de referência em quatro temas: 37 organizacionais, 8 de pessoas, 14 físicos e 34 tecnológicos.		

- A seleção de controles decorre do tratamento de riscos e das obrigações aplicáveis; o Anexo A não é uma lista universal em que todos os controles devam ser sempre implementados.
- A Declaração de Aplicabilidade registra os controles necessários, a justificativa, o status de implementação e as exclusões justificadas do Anexo A.

2. Escopo do SGSI e partes interessadas

Como definir um limite defensável para o sistema de gestão.

- Identificar objetivos de negócio, produtos, serviços, processos, informações, entidades jurídicas, localidades, pessoas, fornecedores, tecnologias e dependências.
- Compreender questões internas relevantes, como estratégia, cultura, competências, arquitetura, governança e recursos.
- Compreender questões externas relevantes, como ameaças, leis, contratos, mercados, fornecedores, condições físicas e mudanças tecnológicas.
- Determinar as partes interessadas e os requisitos pertinentes, incluindo clientes, reguladores, trabalhadores, proprietários, fornecedores, comunidades e partes relacionadas à certificação.
- Considerar se a mudança climática é relevante para a eficácia do SGSI e se as partes interessadas possuem requisitos relacionados ao clima; documentar o raciocínio.
- Definir limites, interfaces, exclusões, dependências e justificativas do escopo em linguagem auditável.
- Manter o escopo alinhado aos inventários de ativos, processos, redes, nuvem, fornecedores e fluxos de dados.

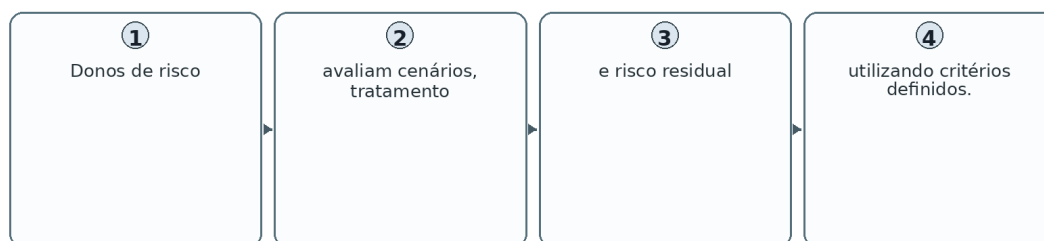
Teste de escopo	Pergunta gerencial	Evidência
Limite	Quais entidades jurídicas, unidades, serviços, processos e tecnologias estão incluídos?	Declaração de escopo aprovada e mapas
Interfaces	O que conecta o escopo a outras equipes, sistemas, fornecedores e localidades?	Fluxos de dados, arquitetura, contratos e matriz de responsabilidades
Compleitude	Informações ou riscos importantes podem estar ocultos fora do limite declarado?	Inventários reconciliados e atividades de descoberta
Mudança	O que aciona uma revisão do escopo?	Registros de mudança, aquisições e pontos de controle de produtos

Teste de escopo	Pergunta gerencial	Evidência
Relevância climática	Efeitos climáticos ou expectativas das partes interessadas podem afetar disponibilidade, fornecedores, instalações, pessoas ou obrigações?	Análise de contexto, decisão e ações quando aplicável

3. Avaliação e tratamento de riscos

Um método repetível que conecta o risco de negócio às decisões sobre controles.

Figura 2. Fluxo de trabalho de risco de segurança da informação



Reconstrução localizada programática para revisão — ISO/IEC 27001/27002

Os proprietários de riscos avaliam cenários, tratamento e risco residual usando critérios definidos.

Figura 2. Fluxo de trabalho de riscos de segurança da informação

Defina os critérios de risco antes da pontuação: método de identificação, escalas de probabilidade e consequência, regras de cálculo, limites de aceitação, tratamento obrigatório, escalonamento, frequência de revisão e autoridade do proprietário do risco. Aplique o método com consistência suficiente para produzir resultados válidos e comparáveis.

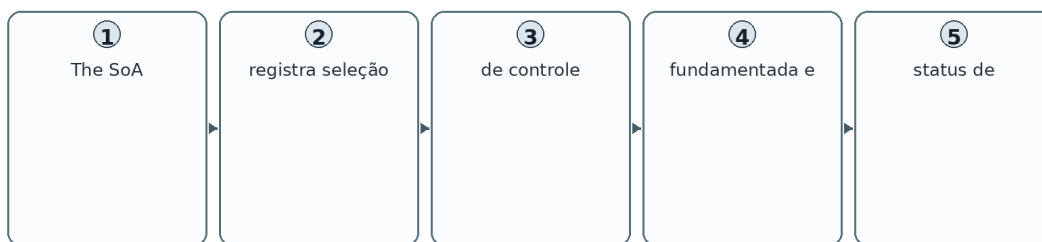
Campo	Conteúdo de exemplo
Ativo ou objetivo	Portal do cliente e disponibilidade exigida contratualmente
Evento de ameaça	Roubo de credenciais seguido de acesso administrativo não autorizado
Vulnerabilidade ou condição	Cadastro fraco e ausência de MFA resistente

Campo	Conteúdo de exemplo
Consequências	a phishing Divulgação de dados, indisponibilidade, violação contratual e custo de resposta
Controles existentes	MFA, acesso condicional, registros e verificação pelo suporte
Risco inerente ou atual	Pontuação conforme critérios aprovados de probabilidade e consequência
Tratamento	Modificar o risco por meio de autenticação mais forte e recuperação monitorada
Proprietário e data	Proprietário responsável pelo risco e data-alvo designados
Risco residual	Reavaliar após o tratamento e obter aprovação explícita do proprietário

4. Declaração de Aplicabilidade

A ponte entre o tratamento de riscos, o Anexo A, outros controles e as evidências de auditoria.

Figura 3. Declaração de fluxo de trabalho de aplicabilidade



Reconstrução localizada programática para revisão — ISO/IEC 27001/27002

A Declaração de Aplicabilidade registra a seleção fundamentada de controles e o status de implementação.

Figura 3. Fluxo de trabalho da Declaração de Aplicabilidade

- Listar os controles necessários para tratar os riscos de segurança da informação identificados e atender aos requisitos legais, regulatórios, contratuais e de negócio.

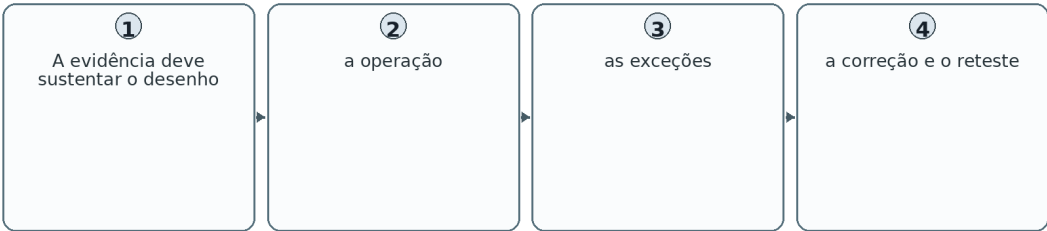
- Comparar os controles selecionados com o Anexo A para verificar se controles de referência necessários não foram ignorados.
- Registrar se cada controle do Anexo A é aplicável e justificar sua inclusão ou exclusão.
- Registrar claramente o status de implementação e mantê-lo coerente com o plano de tratamento de riscos e as evidências operacionais.
- Incluir controles específicos da organização quando o Anexo A não tratar completamente determinado risco.
- Controlar a Declaração de Aplicabilidade como informação documentada e atualizá-la após mudanças materiais em riscos, escopo, requisitos legais, fornecedores, tecnologia ou controles.

Controle	Aplicável?	Justificativa	Status	Responsável / evidência
Exemplo 8.15 — registros de eventos	Sim	Necessário para detecção, investigação e obrigações aplicáveis	Implementado com ações em aberto	Operações de Segurança / inventário de fontes e registros de revisão
Exemplo 7.9 — ativos fora das instalações	Sim	Pessoas em trabalho remoto ou viagem utilizam dispositivos corporativos	Implementado	Operações de TI / inventário e evidência de criptografia
Exemplo de controle organizacional	Sim	Risco específico de segurança de produto exige versões assinadas	Parcialmente implementado	Engenharia / registros de pipeline
Exemplo de exclusão	Não	A tecnologia ou o cenário descrito não existe no escopo controlado	Não aplicável	Evidência de escopo e arquitetura

5. Documentação e evidências

Como manter informações documentadas úteis sem criar burocracia.

Figura 4. Cadeia de exigência à evidência



Reconstrução localizada programática para revisão — ISO/IEC 27001/27002

As evidências devem sustentar o desenho, a operação, as exceções, a correção e o reteste.

Figura 4. Cadeia de requisitos até evidências

Documento ou registro	Finalidade	Verificações de controle
Escopo do SGSI	Define limites e interfaces	Aprovado, atual e coerente com a realidade
Política	Estabelece direção e compromissos	Aprovada, comunicada e revisada
Método e registro de riscos	Demonstra avaliação e decisões repetíveis	Critérios aplicados de forma consistente; proprietários aprovam o risco residual
Plano de tratamento de riscos	Acompanha ações, responsáveis, recursos e datas	Alinhado aos riscos e à Declaração de Aplicabilidade
Declaração de Aplicabilidade	Explica a seleção e o status dos controles	Todos os controles do Anexo A tratados; justificativas sustentadas
Objetivos e métricas	Demonstra resultados planejados e avaliação	Mensuráveis, atribuídos, analisados e usados para ação
Registros de competência e conscientização	Sustentam capacidade e entendimento	Baseados em função, avaliados e atualizados
Evidência operacional	Demonstra que os controles realmente operaram	Completa, autêntica, protegida e retida
Registros de auditoria e revisão	Sustentam supervisão e decisões	Objetivos, completos e acompanhados até a

Documento ou registro	Finalidade	Verificações de controle
Registros de ação corretiva	Demonstram causa-raiz e correção eficaz	conclusão Causa tratada, recorrência considerada e eficácia verificada

6. Cláusula 4 — Contexto da organização

Requisitos em linguagem clara, foco de verificação e exemplos de evidências.

Finalidade da cláusula: Contexto da organização

Cláusula	Significado em linguagem clara	Foco de verificação	Exemplo de evidência
4.1	Compreender questões internas e externas que podem afetar o SGSI; considerar explicitamente se a mudança climática é relevante.	Confirmar responsabilidade, escopo, método, aprovação, evidência operacional, exceções, correção e registros retidos.	Políticas, registros, planos, atas, resultados, aprovações e evidências de acompanhamento.
4.2	Identificar as partes interessadas pertinentes, seus requisitos e se incluem expectativas relacionadas ao clima.	Confirmar responsabilidade, escopo, método, aprovação, evidência operacional, exceções, correção e registros retidos.	Políticas, registros, planos, atas, resultados, aprovações e evidências de acompanhamento.
4.3	Definir e manter o escopo do SGSI, incluindo limites, interfaces, dependências, localidades, tecnologia e exclusões.	Confirmar responsabilidade, escopo, método, aprovação, evidência operacional, exceções, correção e registros retidos.	Políticas, registros, planos, atas, resultados, aprovações e evidências de acompanhamento.
4.4	Estabelecer, operar, manter e melhorar continuamente o SGSI e seus processos obrigatórios.	Confirmar responsabilidade, escopo, método, aprovação, evidência operacional, exceções, correção e	Políticas, registros, planos, atas, resultados, aprovações e evidências de acompanhamento.

Cláusula	Significado em linguagem clara	Foco de verificação	Exemplo de evidência
		registros retidos.	

Use o texto oficial licenciado da ISO/IEC 27001 para consultar os requisitos normativos exatos. Este manual apresenta paráfrases para fins educacionais e não substitui a norma.

Emenda de 2024: Determinar explicitamente se a mudança climática é relevante para o contexto do SGSI e reconhecer que as partes interessadas pertinentes podem ter requisitos relacionados ao clima. Manter evidências do raciocínio e de qualquer ação resultante.

7. Cláusula 5 — Liderança

Requisitos em linguagem clara, foco de verificação e exemplos de evidências.

Finalidade da cláusula: Liderança

Cláusula	Significado em linguagem clara	Foco de verificação	Exemplo de evidência
5.1	A alta direção demonstra comprometimento, integra o SGSI aos processos de negócio, fornece recursos e apoia a melhoria.	Confirmar responsabilidade, escopo, método, aprovação, evidência operacional, exceções, correção e registros retidos.	Políticas, registros, planos, atas, resultados, aprovações e evidências de acompanhamento.
5.2	Estabelecer, comunicar e manter uma política de segurança da informação adequada à organização.	Confirmar responsabilidade, escopo, método, aprovação, evidência operacional, exceções, correção e registros retidos.	Políticas, registros, planos, atas, resultados, aprovações e evidências de acompanhamento.
5.3	Atribuir e comunicar responsabilidades de segurança da informação e autoridade para reporte.	Confirmar responsabilidade, escopo, método, aprovação, evidência operacional, exceções, correção e registros retidos.	Políticas, registros, planos, atas, resultados, aprovações e evidências de acompanhamento.

Use o texto oficial licenciado da ISO/IEC 27001 para consultar os requisitos normativos exatos. Este manual apresenta paráfrases para fins educacionais e não substitui a norma.

8. Cláusula 6 — Planejamento

Requisitos em linguagem clara, foco de verificação e exemplos de evidências.

Finalidade da cláusula: Planejamento

Cláusula	Significado em linguagem clara	Foco de verificação	Exemplo de evidência
6.1.1	Determinar riscos e oportunidades no nível do SGSI, planejar ações, integrá-las aos processos do SGSI e avaliar sua eficácia.	Confirmar responsabilidade, escopo, método, aprovação, evidência operacional, exceções, correção e registros retidos.	Políticas, registros, planos, atas, resultados, aprovações e evidências de acompanhamento.
6.1.2	Definir e aplicar critérios consistentes de risco de segurança da informação e métodos de avaliação; identificar responsáveis e analisar e avaliar os riscos.	Confirmar responsabilidade, escopo, método, aprovação, evidência operacional, exceções, correção e registros retidos.	Políticas, registros, planos, atas, resultados, aprovações e evidências de acompanhamento.
6.1.3	Escolher opções e controles de tratamento de riscos, compará-los ao Anexo A, produzir a Declaração de Aplicabilidade e o plano de tratamento e obter aprovação do responsável pelo risco.	Confirmar responsabilidade, escopo, método, aprovação, evidência operacional, exceções, correção e registros retidos.	Políticas, registros, planos, atas, resultados, aprovações e evidências de acompanhamento.
6.2	Definir objetivos mensuráveis de segurança com responsáveis, recursos, datas e métodos de avaliação.	Confirmar responsabilidade, escopo, método, aprovação, evidência operacional, exceções, correção e registros retidos.	Políticas, registros, planos, atas, resultados, aprovações e evidências de acompanhamento.
6.3	Planejar mudanças no SGSI considerando	Confirmar responsabilidade,	Políticas, registros, planos, atas,

Cláusula	Significado em linguagem clara	Foco de verificação	Exemplo de evidência
	finalidade, consequências, recursos, responsabilidades e integridade do sistema.	escopo, método, aprovação, evidência operacional, exceções, correção e registros retidos.	resultados, aprovações e evidências de acompanhamento.

Use o texto oficial licenciado da ISO/IEC 27001 para consultar os requisitos normativos exatos. Este manual apresenta paráfrases para fins educacionais e não substitui a norma.

9. Cláusula 7 — Apoio

Requisitos em linguagem clara, foco de verificação e exemplos de evidências.

Finalidade da cláusula: Apoio

Cláusula	Significado em linguagem clara	Foco de verificação	Exemplo de evidência
7.1	Fornecer pessoas, orçamento, tecnologia e outros recursos necessários ao SGSI.	Confirmar responsabilidade, escopo, método, aprovação, evidência operacional, exceções, correção e registros retidos.	Políticas, registros, planos, atas, resultados, aprovações e evidências de acompanhamento.
7.2	Definir necessidades de competência, tratar lacunas, avaliar resultados e manter evidências.	Confirmar responsabilidade, escopo, método, aprovação, evidência operacional, exceções, correção e registros retidos.	Políticas, registros, planos, atas, resultados, aprovações e evidências de acompanhamento.
7.3	Assegurar que as pessoas compreendam a política, sua contribuição e as consequências da não conformidade.	Confirmar responsabilidade, escopo, método, aprovação, evidência operacional, exceções, correção e registros retidos.	Políticas, registros, planos, atas, resultados, aprovações e evidências de acompanhamento.
7.4	Planejar o que, quando, com quem e como a organização	Confirmar responsabilidade, escopo, método,	Políticas, registros, planos, atas, resultados,

Cláusula	Significado em linguagem clara	Foco de verificação	Exemplo de evidência
	se comunica interna e externamente.	aprovação, evidência operacional, exceções, correção e registros retidos.	aprovações e evidências de acompanhamento.
7.5	Criar, aprovar, identificar, proteger, distribuir, reter e controlar as informações documentadas necessárias.	Confirmar responsabilidade, escopo, método, aprovação, evidência operacional, exceções, correção e registros retidos.	Políticas, registros, planos, atas, resultados, aprovações e evidências de acompanhamento.

Use o texto oficial licenciado da ISO/IEC 27001 para consultar os requisitos normativos exatos. Este manual apresenta paráfrases para fins educacionais e não substitui a norma.

10. Cláusula 8 — Operação

Requisitos em linguagem clara, foco de verificação e exemplos de evidências.

Finalidade da cláusula: Operação

Cláusula	Significado em linguagem clara	Foco de verificação	Exemplo de evidência
8.1	Planejar e controlar processos do SGSI, critérios, mudanças, trabalho terceirizado e evidências da operação adequada.	Confirmar responsabilidade, escopo, método, aprovação, evidência operacional, exceções, correção e registros retidos.	Políticas, registros, planos, atas, resultados, aprovações e evidências de acompanhamento.
8.2	Realizar avaliações de riscos de segurança da informação em intervalos planejados e quando ocorrerem mudanças significativas.	Confirmar responsabilidade, escopo, método, aprovação, evidência operacional, exceções, correção e registros retidos.	Políticas, registros, planos, atas, resultados, aprovações e evidências de acompanhamento.
8.3	Implementar o plano de tratamento de riscos e manter evidências dos	Confirmar responsabilidade, escopo, método, aprovação, evidência	Políticas, registros, planos, atas, resultados, aprovações e

Cláusula	Significado em linguagem clara	Foco de verificação	Exemplo de evidência
	resultados.	operacional, exceções, correção e registros retidos.	evidências de acompanhamento.

Use o texto oficial licenciado da ISO/IEC 27001 para consultar os requisitos normativos exatos. Este manual apresenta paráfrases para fins educacionais e não substitui a norma.

11. Cláusula 9 — Avaliação de desempenho

Requisitos em linguagem clara, foco de verificação e exemplos de evidências.

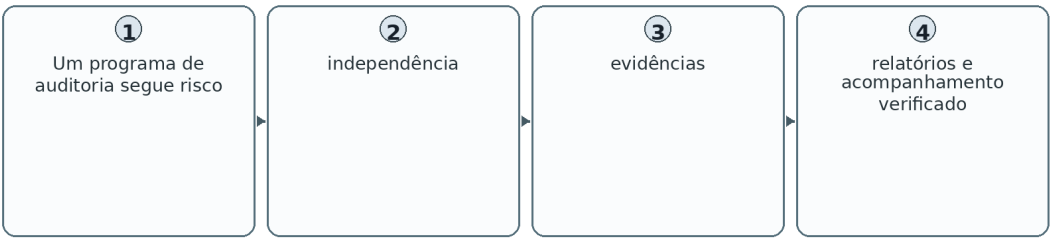
Finalidade da cláusula: Avaliação de desempenho

Cláusula	Significado em linguagem clara	Foco de verificação	Exemplo de evidência
9.1	Definir o que monitorar e medir, como e quando fazê-lo, quem avalia e como os resultados são retidos e analisados.	Confirmar responsabilidade, escopo, método, aprovação, evidência operacional, exceções, correção e registros retidos.	Políticas, registros, planos, atas, resultados, aprovações e evidências de acompanhamento.
9.2.1	Realizar auditorias internas em intervalos planejados para avaliar a conformidade com os requisitos organizacionais e da ISO/IEC 27001 e a eficácia da implementação.	Confirmar responsabilidade, escopo, método, aprovação, evidência operacional, exceções, correção e registros retidos.	Políticas, registros, planos, atas, resultados, aprovações e evidências de acompanhamento.
9.2.2	Manter um programa de auditoria com frequência, métodos, responsabilidades, planejamento, reporte, escopo, critérios, auditores objetivos, resultados retidos e ação	Confirmar responsabilidade, escopo, método, aprovação, evidência operacional, exceções, correção e registros retidos.	Políticas, registros, planos, atas, resultados, aprovações e evidências de acompanhamento.

Cláusula	Significado em linguagem clara	Foco de verificação	Exemplo de evidência
	corretiva tempestiva.		
9.3.1	A alta direção analisa o SGSI em intervalos planejados quanto à adequação, suficiência e eficácia contínuas.	Confirmar responsabilidade, escopo, método, aprovação, evidência operacional, exceções, correção e registros retidos.	Políticas, registros, planos, atas, resultados, aprovações e evidências de acompanhamento.
9.3.2	Analisar entradas obrigatórias, como ações anteriores, mudanças de contexto, necessidades das partes interessadas, desempenho, feedback, riscos, tratamento e oportunidades de melhoria.	Confirmar responsabilidade, escopo, método, aprovação, evidência operacional, exceções, correção e registros retidos.	Políticas, registros, planos, atas, resultados, aprovações e evidências de acompanhamento.
9.3.3	Registrar decisões da análise crítica da direção sobre melhorias e mudanças necessárias no SGSI.	Confirmar responsabilidade, escopo, método, aprovação, evidência operacional, exceções, correção e registros retidos.	Políticas, registros, planos, atas, resultados, aprovações e evidências de acompanhamento.

Use o texto oficial licenciado da ISO/IEC 27001 para consultar os requisitos normativos exatos. Este manual apresenta paráfrases para fins educacionais e não substitui a norma.

Figura 5. Fluxo de trabalho de auditoria interna



Reconstrução localizada programática para revisão — ISO/IEC 27001/27002

Um programa de auditoria considera riscos, independência, evidências, reporte e acompanhamento verificado.

Figura 5. Fluxo de trabalho da auditoria interna

12. Cláusula 10 — Melhoria

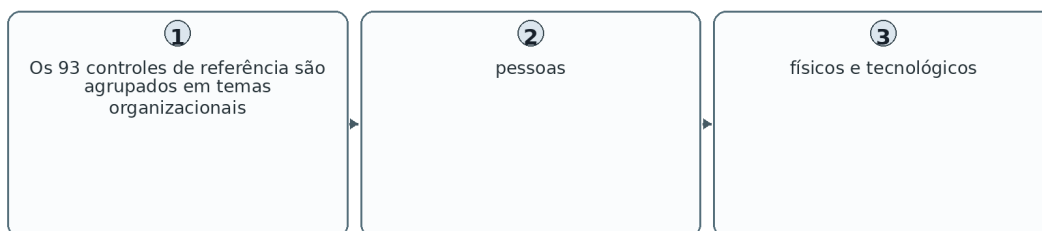
Requisitos em linguagem clara, foco de verificação e exemplos de evidências.

Finalidade da cláusula: Melhoria

Cláusula	Significado em linguagem clara	Foco de verificação	Exemplo de evidência
10.1	Melhorar continuamente a adequação, suficiência e eficácia do SGSI.	Confirmar responsabilidade, escopo, método, aprovação, evidência operacional, exceções, correção e registros retidos.	Políticas, registros, planos, atas, resultados, aprovações e evidências de acompanhamento.
10.2	Reagir às não conformidades, corrigi-las, analisar causas, prevenir recorrência, verificar a eficácia e manter evidências.	Confirmar responsabilidade, escopo, método, aprovação, evidência operacional, exceções, correção e registros retidos.	Políticas, registros, planos, atas, resultados, aprovações e evidências de acompanhamento.

Use o texto oficial licenciado da ISO/IEC 27001 para consultar os requisitos normativos exatos. Este manual apresenta paráfrases para fins educacionais e não substitui a norma.

Figura 6. Temas de controle do anexo A



Reconstrução localizada programática para revisão — ISO/IEC 27001/27002

Os 93 controles de referência estão agrupados em temas organizacionais, de pessoas, físicos e tecnológicos.

Figura 6. Temas dos controles do Anexo A

13. Anexo A 5 Controles organizacionais

- Resumos originais dos controles de referência, foco de verificação e exemplos de provas.*

Controle	Significado prático	Foco de verificação	Exemplo de evidência
5.1	Manter políticas de segurança da informação aprovadas.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
5.2	Defina funções e responsabilidades de segurança.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
5.3	Funções conflitantes separadas.	Confirmar risco ou obrigação, design, proprietário,	Procedimento, configuração, registro, registro,

Controle	Significado prático	Foco de verificação	Exemplo de evidência
		implementação, operação, exceções e medição.	ticket, revisão, teste ou observação.
5.4	Requerer que os gestores executem as responsabilidades de segurança.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
5.5	Manter o contato apropriado com as autoridades.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
5.6	Participe de grupos de segurança relevantes e fóruns profissionais.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
5.7	Colete e use a inteligência de ameaça.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
5.8	Criar segurança na gestão de projetos.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
5.9	Informações de inventário e ativos associados.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
5.10	Definição de regras de uso e manuseio aceitáveis.	Confirmar risco ou obrigação, design, proprietário,	Procedimento, configuração, registro, registro,

Controle	Significado prático	Foco de verificação	Exemplo de evidência
		implementação, operação, exceções e medição.	ticket, revisão, teste ou observação.
5.11	Recupere ativos organizacionais quando os papéis terminarem ou mudarem.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
5.12	Classifique informações de acordo com a necessidade e risco.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
5.13	Informação do rótulo consistente com a classificação.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
5.14	Proteger as transferências de informação.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
5.15	Estabelecer regras de acesso-controle.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
5.16	Gerenciar identidades ao longo de seu ciclo de vida.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
5.17	Proteger informações de autenticação.	Confirmar risco ou obrigação, design, proprietário,	Procedimento, configuração, registro, registro,

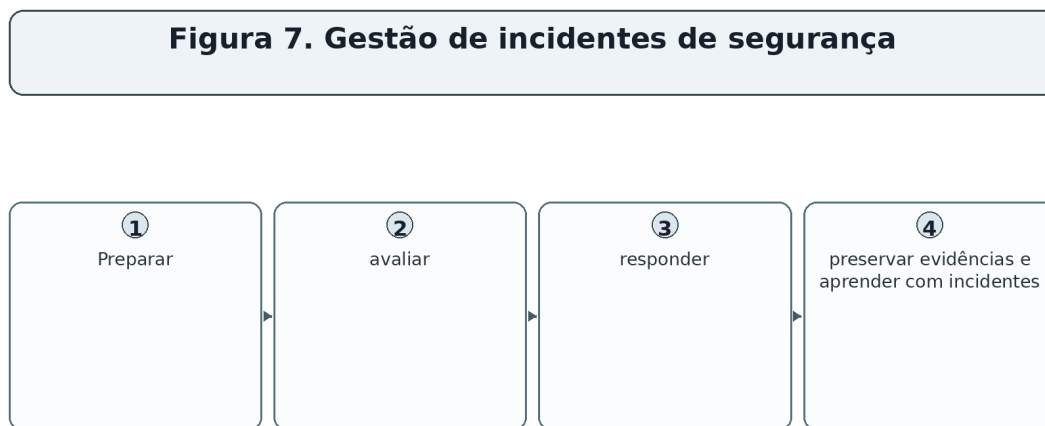
Controle	Significado prático	Foco de verificação	Exemplo de evidência
		implementação, operação, exceções e medição.	ticket, revisão, teste ou observação.
5.18	Aprovar, rever, modificar e remover direitos de acesso.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
5.19	Gerenciar risco de segurança nas relações de fornecedores.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
5.20	Inclua os requisitos de segurança nos acordos de fornecedores.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
5.21	Gerencie o risco de segurança da cadeia de fornecimento de TIC.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
5.22	Monitorar, rever e controlar as mudanças entre fornecedores e serviços.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
5.23	Governar aquisição, uso, gerenciamento e saída dos serviços de nuvem.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
5.24	Preparar e planejar a gestão de incidentes de segurança.	Confirmar risco ou obrigação, design, proprietário,	Procedimento, configuração, registro, registro,

Controle	Significado prático	Foco de verificação	Exemplo de evidência
		implementação, operação, exceções e medição.	ticket, revisão, teste ou observação.
5.25	Avaliar eventos e decidir se eles são incidentes.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
5.26	Responder a incidentes de segurança.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
5.27	Aprenda com incidentes e melhore os controles.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
5.28	Identifique, recolha, adquira e preserve a evidência.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
5.29	Proteger a informação durante a interrupção.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
5.30	Preparar as TIC para apoiar a continuidade do negócio.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
5.31	Identifique e atenda aos requisitos legais, regulamentares e	Confirmar risco ou obrigação, design, proprietário,	Procedimento, configuração, registro, registro,

Controle	Significado prático	Foco de verificação	Exemplo de evidência
	contratuais.	implementação, operação, exceções e medição.	ticket, revisão, teste ou observação.
5.32	Proteger os direitos de propriedade intelectual.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
5.33	Proteger os registros durante todo o seu ciclo de vida.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
5.34	Proteger a privacidade e as informações pessoalmente identificáveis.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
5.35	Organize avaliações independentes da segurança da informação.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
5.36	Verificar o cumprimento das políticas de segurança, regras e normas.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
5.37	Manter procedimentos operacionais documentados.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.

Regra de seleção: O Anexo A é um conjunto de referência usado para verificar se controles necessários não foram ignorados. A organização pode precisar de outros controles. Toda

inclusão ou exclusão deve ser justificada pelo tratamento de riscos e registrada na Declaração de Aplicabilidade.



Reconstrução localizada programática para revisão — ISO/IEC 27001/27002

Preparar, avaliar, responder, preservar evidências e aprender com incidentes.

Figura 7. Gestão de incidentes de segurança

14. Anexo A 6 As pessoas controlam

- Resumos originais dos controles de referência, foco de verificação e exemplos de provas.*

Controle	Significado prático	Foco de verificação	Exemplo de evidência
6.1	Candidatos de tela e pessoal de acordo com a lei, o papel e o risco.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
6.2	Incluir responsabilidades de segurança em termos de emprego.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
6.3	Fornecer consciencialização, educação e formação baseadas em funções.	Confirmar risco ou obrigação, design, proprietário, implementação,	Procedimento, configuração, registro, registro, ticket, revisão, teste

Controle	Significado prático	Foco de verificação	Exemplo de evidência
		operação, exceções e medição.	ou observação.
6.4	Opere um processo disciplinar justo e comunicado.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
6.5	Gerenciar os deveres de segurança após a cessação ou mudança de função.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
6.6	Use acordos adequados de confidencialidade ou não divulgação.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
6.7	Proteger a informação durante o trabalho remoto.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
6.8	Tornar a comunicação de eventos de segurança fácil e oportuna.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.

Regra de seleção: O Anexo A é um conjunto de referência usado para verificar se controles necessários não foram ignorados. A organização pode precisar de outros controles. Toda inclusão ou exclusão deve ser justificada pelo tratamento de riscos e registrada na Declaração de Aplicabilidade.

15. Anexo A 7 Controles físicos

- Resumos originais dos controles de referência, foco de verificação e exemplos de provas.*

Controle	Significado prático	Foco de verificação	Exemplo de evidência
7.1	Defina e proteja perímetros de segurança física.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
7.2	Controle a entrada física.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
7.3	Escritórios seguros, quartos e instalações.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
7.4	Monitorar instalações para acesso físico não autorizado.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
7.5	Proteger contra ameaças físicas e ambientais.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
7.6	Aplicar regras de trabalho para áreas seguras.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
7.7	Use práticas claras e de tela clara.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.

Controle	Significado prático	Foco de verificação	Exemplo de evidência
7.8	Local e proteger o equipamento apropriadamente.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
7.9	Proteger os activos utilizados fora das instalações organizacionais.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
7.10	Gerencie os meios de armazenamento ao longo de seu ciclo de vida.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
7.11	Proteger utilitários de suporte.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
7.12	Proteger a energia e o cabeamento de dados.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
7.13	h Mantenha o equipamento com segurança.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
7.14	Eliminar ou reutilizar equipamentos com segurança.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.

Regra de seleção: O Anexo A é um conjunto de referência usado para verificar se controles necessários não foram ignorados. A organização pode precisar de outros controles. Toda inclusão ou exclusão deve ser justificada pelo tratamento de riscos e registrada na Declaração de Aplicabilidade.

16. Anexo A 8 Controles tecnológicos

- Resumos originais dos controles de referência, foco de verificação e exemplos de provas.*

Controle	Significado prático	Foco de verificação	Exemplo de evidência
8.1	Dispositivos de endpoint do utilizador seguros.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
8.2	Controle os direitos de acesso privilegiados.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
8.3	Restrinja o acesso à informação de acordo com a política.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
8.4	Controle o acesso ao código fonte e ferramentas de desenvolvimento.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
8.5	Use autenticação segura.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
8.6	Gerenciar capacidade.	Confirmar risco ou obrigação, design, proprietário,	Procedimento, configuração, registro, registro,

Controle	Significado prático	Foco de verificação	Exemplo de evidência
		implementação, operação, exceções e medição.	ticket, revisão, teste ou observação.
8.7	Proteger contra malware.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
8.8	Gerenciar vulnerabilidades técnicas.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
8.9	Gerenciar configurações.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
8.10	, apagar informações de forma segura quando já não é necessário.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
8.11	Máscara de dados sensíveis quando apropriado.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
8.12	Evite vazamento de dados.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
8.13	Manter e testar backups.	Confirmar risco ou obrigação, design, proprietário,	Procedimento, configuração, registro, registro,

Controle	Significado prático	Foco de verificação	Exemplo de evidência
		implementação, operação, exceções e medição.	ticket, revisão, teste ou observação.
8.14	Fornecer redundância onde a disponibilidade o exija.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
8.15	Gerar, proteger, reter e rever logs.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
8.16	sistemas de monitoramento e redes para comportamento anormal.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
8.17	Sincronizar relógios.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
8.18	Controlar utilitários poderosos do sistema.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
8.19	- Instalação de software de controle em sistemas operacionais.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
8.20	Redes seguras.	Confirmar risco ou obrigação, design, proprietário,	Procedimento, configuração, registro, registro,

Controle	Significado prático	Foco de verificação	Exemplo de evidência
		implementação, operação, exceções e medição.	ticket, revisão, teste ou observação.
8.21	Serviços de rede seguros.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
8.22	Segregate redes onde necessário.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
8.23	Controle o acesso a sites externos.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
8.24	Use e gerencie a criptografia apropriadamente.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
8.25	Opere um ciclo de vida de desenvolvimento seguro.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
8.26	Defina requisitos de segurança da aplicação.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
8.27	, aplicar princípios seguros de arquitetura e	Confirmar risco ou obrigação, design, proprietário,	Procedimento, configuração, registro, registro,

Controle	Significado prático	Foco de verificação	Exemplo de evidência
	engenharia.	implementação, operação, exceções e medição.	ticket, revisão, teste ou observação.
8.28	Use práticas de codificação seguras.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
8.29	Ou Execute testes de segurança no desenvolvimento e aceitação.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
8.30	Controle o desenvolvimento terceirizado.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
8.31	Ambientes de desenvolvimento, teste e produção separados.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
8.32	Gerenciar as mudanças com segurança.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
8.33	Proteger a informação do teste.	Confirmar risco ou obrigação, design, proprietário, implementação, operação, exceções e medição.	Procedimento, configuração, registro, registro, ticket, revisão, teste ou observação.
8.34	Proteger os sistemas operacionais durante os testes de auditoria.	Confirmar risco ou obrigação, design, proprietário,	Procedimento, configuração, registro, registro,

Controle	Significado prático	Foco de verificação	Exemplo de evidência
		implementação, operação, exceções e medição.	ticket, revisão, teste ou observação.

Regra de seleção: O Anexo A é um conjunto de referência usado para verificar se controles necessários não foram ignorados. A organização pode precisar de outros controles. Toda inclusão ou exclusão deve ser justificada pelo tratamento de riscos e registrada na Declaração de Aplicabilidade.

17. Implementação de Controles com a ISO/IEC 27002

Como transformar decisões de risco em controles adequados à organização.

1. Comece pela decisão de tratamento de risco, pela obrigação aplicável e pelo resultado esperado — não por uma ferramenta.
2. Use as orientações da ISO/IEC 27002 e seus atributos relevantes para compreender a finalidade, as considerações de implementação e as relações entre controles.
3. Adapte o controle às pessoas, aos processos, à tecnologia, ao ambiente físico, às restrições legais e às operações do negócio.
4. Defina proprietário, escopo, gatilho, entradas, etapas, saídas, registros, frequência, dependências, exceções e escalonamento.
5. Avalie se o desenho do controle pode alcançar razoavelmente o resultado pretendido.
6. Implemente por meio de mudança controlada e treine as pessoas afetadas.
7. Meça a operação e a eficácia, investigue exceções e melhore o controle.
8. Atualize riscos, plano de tratamento, Declaração de Aplicabilidade, procedimentos e evidências quando o controle mudar.

Distinção importante: A ISO/IEC 27002 fornece orientação. A organização continua responsável por selecionar e desenhar controles que tratem seus riscos e atendam aos requisitos aplicáveis.

18. Métricas e Testes de Controle

Como verificar se o SGSI e seus controles funcionam.

Área	População e amostra	Teste	Evidência
Risco	Todos os riscos	Reexecutar a	Método, registro,

Área	População e amostra	Teste	Evidência
	atuais; amostra de itens altos, alterados, aceitos e vencidos	pontuação, rastrear o tratamento e confirmar aprovação e revisão pelo proprietário	aprovações, tratamento e risco residual
Acesso	Todas as identidades de funcionários, privilegiadas, de serviço e de terceiros	Testar necessidade, aprovação, MFA, revisão, alteração, inatividade e desligamento	Populações, exportações, tickets, configurações e logs
Vulnerabilidades	Todos os ativos e achados	Validar cobertura, priorização, exceções, prazos, correção e nova varredura	Inventário, varreduras, tickets, aprovações e retestes
Fornecedores	População completa de fornecedores; amostra de serviços críticos e alterados	Testar diligência, acordo, responsabilidades, monitoramento, incidente e saída	Inventário, avaliação, contrato, revisão e prova de encerramento
Incidentes	Todos os eventos e incidentes relatados	Testar classificação, resposta, evidências, comunicações, recuperação e aprendizado	Casos, cronologia, decisões, registro de evidências e lições
Continuidade	Processos críticos e TIC de suporte	Rastrear necessidades do negócio até o desenho de recuperação e os exercícios	BIA, planos, registros de testes, lacunas e retestes
Objetivos	Todos os objetivos e medidas do SGSI	Verificar definição, qualidade dos dados, tendência, meta, análise, decisão e ação	Definições de métricas, dados-fonte, painéis, atas e ações

- Defina critérios, escopo, período, população, controle, proprietário, evidência e resultado esperado.
- Avalie o desenho antes de testar a operação.
- Obtenha a população completa e valide sua integridade e exatidão de forma independente.
- Selecione uma amostra baseada em risco que cubra datas, proprietários, locais, falhas, exceções e mudanças relevantes.

- Inspeção registros, observe o trabalho, entreviste pessoas, examine configurações e reexecute procedimentos quando viável.
- Documente exceções como fatos vinculados aos critérios; não exagere nem oculte limitações.
- Atribua correção, análise de causa raiz, proprietário, prazo, proteção provisória e escalonamento.
- Reteste e declare a conclusão final e qualquer limitação remanescente.

19. Auditoria Interna

Uma avaliação independente da conformidade e da implementação eficaz.

Mantenha um programa de auditoria que considere importância dos processos, mudanças, riscos e resultados anteriores.

Defina objetivo, escopo, critérios, momento, método, amostragem, registros e comunicação para cada auditoria.

Selecione auditores competentes e suficientemente objetivos; auditores não devem auditar o próprio trabalho sem salvaguardas.

Use a norma licenciada, requisitos organizacionais, decisões de risco, Declaração de Aplicabilidade, políticas e obrigações aplicáveis como critérios.

Registre evidências e achados com clareza suficiente para que outra pessoa competente compreenda sua base.

Comunique os resultados à gestão relevante e acompanhe correções e ações corretivas até a verificação de eficácia.

Tipo de achado	Significado	Resposta exigida
Conformidade	A evidência sustenta os critérios	Manter e monitorar
Oportunidade de melhoria	Sugestão útil que não encobre uma não conformidade	Avaliar voluntariamente e registrar a decisão
Não conformidade	Um ou mais requisitos não foram atendidos	Corrigir, analisar a causa, prevenir recorrência e verificar eficácia
Limitação da auditoria	Escopo, evidência, tempo, independência ou acesso restringiram a conclusão	Divulgar claramente e resolver quando possível

20. Análise Crítica pela Direção e Ação Corretiva

Decisões de liderança que mantêm o SGSI adequado e eficaz.

Entrada da análise crítica	Perguntas
Ações anteriores	As decisões anteriores foram concluídas e eficazes?
Contexto e partes interessadas	O que mudou, incluindo relevância climática e necessidades das partes interessadas?
Desempenho	O que mostram métricas, objetivos, incidentes, auditorias e não conformidades?
Retorno das partes interessadas	O que relatam clientes, reguladores, trabalhadores, fornecedores e proprietários?
Risco e tratamento	Níveis de risco, aceitação, tratamento, recursos e Declaração de Aplicabilidade continuam adequados?
Oportunidades de melhoria	Quais mudanças a liderança deve aprovar?
• Contenha ou corrija o problema imediato. • Determine a extensão e se existem falhas semelhantes em outros locais. • Analise a causa raiz com evidências, sem atribuição simplista de culpa. • Planeje ações proporcionais ao efeito e ao risco de recorrência. • Implemente mudanças com proprietário e prazo definidos. • Verifique a eficácia com evidências definidas após tempo suficiente de operação. • Atualize riscos, controles, documentos, treinamento, objetivos e Declaração de Aplicabilidade quando necessário.	

21. Preparação para Certificação

O que a certificação faz, como normalmente ocorre e o que ela não garante.

Figura 8. Caminho de certificação



Reconstrução localizada programática para revisão — ISO/IEC 27001/27002

A preparação é seguida pela avaliação de certificação e por atividades contínuas de supervisão e renovação.

Figura 8. Caminho para certificação

A certificação é opcional; organizações podem implementar a ISO/IEC 27001 sem buscar um certificado.

A ISO não realiza certificações. Um organismo de certificação independente conduz as auditorias de certificação.

A acreditação oferece confiança adicional na competência de um organismo de certificação; verifique o escopo relevante da acreditação e do certificado.

A Fase 1 normalmente avalia prontidão, escopo, sistema documentado e preparação para a auditoria de implementação.

A Fase 2 avalia implementação e eficácia em todo o escopo definido.

Atividades de supervisão e recertificação avaliam a conformidade contínua; confirme os detalhes com o organismo de certificação selecionado e as regras de acreditação.

Um certificado tem escopo e prazo definidos. Ele não prova que todo produto é seguro, que nenhum incidente ocorrerá ou que todos os sistemas da empresa estão incluídos.

Área de prontidão	Critério de aceitação
Escopo	Claro, defensável e refletido nas operações reais e na intenção do certificado
Risco	Método usado de forma consistente; registro completo; proprietários aceitam o risco residual

Área de prontidão	Critério de aceitação
Declaração de Aplicabilidade	Todos os controles do Anexo A abordados; seleções, exclusões e status sustentados
Controles	Implementados, operados por tempo suficiente para gerar evidência confiável e medidos
Auditoria interna	Programa e auditoria de escopo completo concluídos com evidência objetiva e acompanhamento
Análise crítica pela direção	Entradas exigidas consideradas e decisões registradas
Ação corretiva	Não conformidades corrigidas; causa e eficácia tratadas
Emenda	Relevância climática e requisitos das partes interessadas considerados e evidenciados

22. Ferramentas de Código Aberto

Links oficiais, inícios rápidos seguros, evidências e limitações.

Ferramenta	Finalidade	Possível apoio
CISO Assistant	SGSI, riscos, controles e evidências	Implante em laboratório isolado; configure escopo, riscos, tratamentos, proprietários e evidências.
SimpleRisk Community	Registro e tratamento de riscos	Defina critérios, registre riscos e proprietários, selecione tratamentos e acompanhe prazos.
Wazuh	SIEM, monitoramento de endpoint e FIM	Instale gerente e agente em laboratório, gere evento autorizado e preserve configuração e alerta.
osquery	Inventário e consultas de endpoint	Execute consultas somente leitura em host de laboratório e documente cobertura e resultados.
OpenSCAP	Avaliação de configuração Linux	Selecione perfil apropriado, examine sistema de laboratório, valide achados, corrija e repita.
Greenbone Community	Gestão de vulnerabilidades	Autorize alvos, atualize feeds,

Ferramenta	Finalidade	Possível apoio
Edition		execute varredura autenticada, valide e reteste.
Nmap	Descoberta de ativos e serviços	Use apenas em faixas autorizadas; limite a varredura e compare com o inventário.
Trivy	Código, imagem, dependência, segredo e configuração	Examine repositório ou imagem de teste, valide, corrija e reescaneie.
OWASP ZAP	Teste autorizado de aplicações web	Use aplicação de treinamento; mantenha varredura ativa sob aprovação escrita.
Keycloak	Identidade, MFA, funções e logs	Crie ambiente de laboratório, usuários, grupos, menor privilégio e casos de entrada, mudança e saída.
DefectDojo	Ingestão e remediação de achados	Importe resultados seguros, deduplique, atribua responsáveis e encerre somente após reteste.
AIDE	Monitoramento de integridade de arquivos	Crie linha de base, faça mudança autorizada, execute verificação e proteja a linha de base.
Lynis	Auditoria de segurança Linux	Audite host de laboratório, avalie sugestões contra risco, corrija itens e execute novamente.
Open Policy Agent	Política como código	Escreva regra de laboratório, teste entradas permitidas e negadas e preserve resultados.

Limitação crítica: Ferramentas apoiam controles e evidências; elas não selecionam tratamento de risco, determinam conformidade, substituem auditores competentes nem certificam uma organização. Valide cobertura, qualidade de dados, configuração, permissões, atualizações e revisão humana.

22.1 CISO Assistant

Objetivo: SGSI, riscos, controles e evidências. Projeto oficial: [CISO Assistant](#)

Início rápido seguro: Implante em laboratório isolado; configure escopo, riscos, tratamentos, proprietários e evidências.

Evidência: escopo aprovado, configuração, versão, cobertura, resultados, revisão, exceção, remediação e reteste. Proteja credenciais, registros, relatórios e backups.

22.2 SimpleRisk Community

Objetivo: Registro e tratamento de riscos. Projeto oficial: [SimpleRisk Community](#)

Início rápido seguro: Defina critérios, registre riscos e proprietários, selecione tratamentos e acompanhe prazos.

Evidência: escopo aprovado, configuração, versão, cobertura, resultados, revisão, exceção, remediação e reteste. Proteja credenciais, registros, relatórios e backups.

22.3 Wazuh

Objetivo: SIEM, monitoramento de endpoint e FIM. Projeto oficial: [Wazuh](#)

Início rápido seguro: Instale gerente e agente em laboratório, gere evento autorizado e preserve configuração e alerta.

Evidência: escopo aprovado, configuração, versão, cobertura, resultados, revisão, exceção, remediação e reteste. Proteja credenciais, registros, relatórios e backups.

22.4 osquery

Objetivo: Inventário e consultas de endpoint. Projeto oficial: [osquery](#)

Início rápido seguro: Execute consultas somente leitura em host de laboratório e documente cobertura e resultados.

Evidência: escopo aprovado, configuração, versão, cobertura, resultados, revisão, exceção, remediação e reteste. Proteja credenciais, registros, relatórios e backups.

22.5 OpenSCAP

Objetivo: Avaliação de configuração Linux. Projeto oficial: [OpenSCAP](#)

Início rápido seguro: Selecione perfil apropriado, examine sistema de laboratório, valide achados, corrija e repita.

Evidência: escopo aprovado, configuração, versão, cobertura, resultados, revisão, exceção, remediação e reteste. Proteja credenciais, registros, relatórios e backups.

22.6 Greenbone Community Edition

Objetivo: Gestão de vulnerabilidades. Projeto oficial: [Greenbone Community Edition](#)

Início rápido seguro: Autorize alvos, atualize feeds, execute varredura autenticada, valide e reteste.

Evidência: escopo aprovado, configuração, versão, cobertura, resultados, revisão, exceção, remediação e reteste. Proteja credenciais, registros, relatórios e backups.

22.7 Nmap

Objetivo: Descoberta de ativos e serviços. Projeto oficial: [Nmap](#)

Início rápido seguro: Use apenas em faixas autorizadas; limite a varredura e compare com o inventário.

Evidência: escopo aprovado, configuração, versão, cobertura, resultados, revisão, exceção, remediação e reteste. Proteja credenciais, registros, relatórios e backups.

22.8 Trivy

Objetivo: Código, imagem, dependência, segredo e configuração. Projeto oficial: [Trivy](#)

Início rápido seguro: Examine repositório ou imagem de teste, valide, corrija e reescaneie.

Evidência: escopo aprovado, configuração, versão, cobertura, resultados, revisão, exceção, remediação e reteste. Proteja credenciais, registros, relatórios e backups.

22.9 OWASP ZAP

Objetivo: Teste autorizado de aplicações web. Projeto oficial: [OWASP ZAP](#)

Início rápido seguro: Use aplicação de treinamento; mantenha varredura ativa sob aprovação escrita.

Evidência: escopo aprovado, configuração, versão, cobertura, resultados, revisão, exceção, remediação e reteste. Proteja credenciais, registros, relatórios e backups.

22.10 Keycloak

Objetivo: Identidade, MFA, funções e logs. Projeto oficial: [Keycloak](#)

Início rápido seguro: Crie ambiente de laboratório, usuários, grupos, menor privilégio e casos de entrada, mudança e saída.

Evidência: escopo aprovado, configuração, versão, cobertura, resultados, revisão, exceção, remediação e reteste. Proteja credenciais, registros, relatórios e backups.

22.11 DefectDojo

Objetivo: Ingestão e remediação de achados. Projeto oficial: [DefectDojo](#)

Início rápido seguro: Importe resultados seguros, deduplique, atribua responsáveis e encerre somente após reteste.

Evidência: escopo aprovado, configuração, versão, cobertura, resultados, revisão, exceção, remediação e reteste. Proteja credenciais, registros, relatórios e backups.

22.12 AIDE

Objetivo: Monitoramento de integridade de arquivos. Projeto oficial: [AIDE](#)

Início rápido seguro: Crie linha de base, faça mudança autorizada, execute verificação e proteja a linha de base.

Evidência: escopo aprovado, configuração, versão, cobertura, resultados, revisão, exceção, remediação e reteste. Proteja credenciais, registros, relatórios e backups.

22.13 Lynis

Objetivo: Auditoria de segurança Linux. Projeto oficial: [Lynis](#)

Início rápido seguro: Audite host de laboratório, avalie sugestões contra risco, corrija itens e execute novamente.

Evidência: escopo aprovado, configuração, versão, cobertura, resultados, revisão, exceção, remediação e reteste. Proteja credenciais, registros, relatórios e backups.

22.14 Open Policy Agent

Objetivo: Política como código. Projeto oficial: [Open Policy Agent](#)

Início rápido seguro: Escreva regra de laboratório, teste entradas permitidas e negadas e preserve resultados.

Evidência: escopo aprovado, configuração, versão, cobertura, resultados, revisão, exceção, remediação e reteste. Proteja credenciais, registros, relatórios e backups.

23. Manual do SGSI para Gestores

Perguntas, painel, propriedade e decisões que os gestores devem controlar.

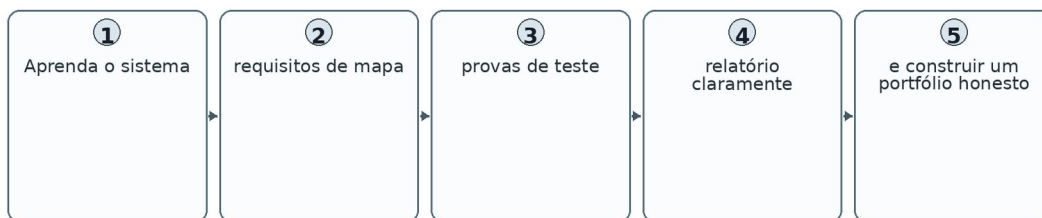
- O escopo do SGSI continua alinhado à estratégia, aos serviços, locais, fornecedores, nuvem, pessoas e fluxos de dados?
- O que mudou no contexto, nas partes interessadas, nas obrigações, ameaças, tecnologia ou relevância climática?
- Os critérios de risco são confiáveis e os proprietários aprovam explicitamente tratamento e risco residual?
- A Declaração de Aplicabilidade corresponde à implementação real dos controles e às ações abertas?
- Objetivos e métricas geram decisões, em vez de painéis decorativos?
- Incidentes, achados, exceções, ações vencidas e falhas recorrentes são escalonados?
- Auditoria interna e análise crítica têm independência, competência, tempo e evidência suficientes?
- Alegações de certificação, escopo, acreditação e declarações a clientes são exatas?

Área	Pergunta de controle	Estado
Contexto e escopo	Limites, dependências, partes e mudanças estão atuais?	Verde / Amarelo / Vermelho
Risco	CrITÉrios são consistentes e decisões dos proprietários são oportunas?	Verde / Amarelo / Vermelho
SoA e controles	Seleção, estado e evidência estão alinhados?	Verde / Amarelo / Vermelho
Desempenho	Objetivos, métricas, incidentes e tendências impulsionam ação?	Verde / Amarelo / Vermelho
Fornecedores	Risco, responsabilidade, monitoramento, incidentes e saída são controlados?	Verde / Amarelo / Vermelho
Auditoria	Auditorias são objetivas e achados são corrigidos com eficácia?	Verde / Amarelo / Vermelho
Melhoria	Causas, recorrência e lições são tratadas?	Verde / Amarelo / Vermelho
Certificação	Alegações são verificadas, atuais e sustentáveis?	Verde / Amarelo / Vermelho

24. Guia de Carreira para Analista Júnior

Uma rota prática para trabalho com SGSI, GRC, risco, auditoria e conformidade.

Figura 9. Caminho de analista ISO 27001 Júnior



Reconstrução localizada programática para revisão — ISO/IEC 27001/27002

Aprenda o sistema, mapeie requisitos, teste evidências, comunique claramente e construa um portfólio honesto.

Figura 9. Caminho do analista júnior de ISO 27001

Funções iniciais comuns incluem analista júnior de GRC, analista de conformidade ISO 27001, analista de controles de segurança, coordenador de SGSI, analista de riscos, associado de auditoria interna, analista de risco de terceiros e analista de garantia de segurança.

24.1 Trabalho júnior típico

- Manter registros de escopo, ativos, obrigações, fornecedores, riscos, controles, SoA, evidências, achados e ações.
- Coletar evidências sem alterar registros e validar sua integridade.
- Mapear riscos e requisitos para controles, proprietários, procedimentos, sistemas e evidências.
- Testar amostras de acesso, mudanças, vulnerabilidades, incidentes, backups, fornecedores, conscientização, controles físicos e continuidade.
- Apoiar auditorias, análise crítica, métricas, ações corretivas e preparação para certificação.
- Escrever conclusões factuais e divulgar limitações de amostragem, escopo e evidência.
- Proteger informações confidenciais e permanecer dentro da autorização.

24.2 Competências valorizadas

Competência	Prova prática
Conceitos de SGSI	Explicar cláusulas 4–10 e melhoria contínua
Risco	Criar registro e plano de tratamento consistentes
Declaração de Aplicabilidade	Justificar seleções, exclusões, estado e evidências
Teste de evidência	Definir população, amostra, procedimento, exceção e reteste
Alfabetização técnica	Interpretar identidade, nuvem, logs, vulnerabilidade, backup e configuração
Comunicação	Escrever conclusões, ações e resumos gerenciais concisos
Ética	Usar dados sintéticos, sistemas autorizados e alegações honestas

25. Laboratório Fictício e Portfólio

Um ambiente de prática segura com dados sintéticos e sistemas de laboratório autorizados.

Regra do laboratório: Use organização fictícia, dados sintéticos, sistemas isolados e apenas ferramentas que você está autorizado a operar. Não apresente um projeto de portfólio como certificação real ou auditoria de cliente.

1. Crie uma empresa fictícia com dois produtos, um serviço em nuvem, força de trabalho remota e três fornecedores.
2. Produza análise de contexto, registro de partes interessadas, avaliação de relevância climática e declaração de escopo.
3. Defina critérios e um registro com dez cenários de risco, proprietários e decisões de tratamento.
4. Crie plano de tratamento e Declaração de Aplicabilidade cobrindo os 93 controles do Anexo A com justificativas e estado honesto.
5. Desenvolva políticas, procedimentos, objetivos, métricas, registros de ativos e fornecedores, treinamento, incidente e exercício de continuidade.
6. Use poucas ferramentas abertas em laboratório isolado e preserve escopo, configuração, resultados, validação, remediação e reteste.
7. Planeje e execute auditoria interna limitada contra cláusulas e controles selecionados.
8. Escreva duas não conformidades, análises de causa, ações corretivas e testes de eficácia.
9. Produza ata de análise crítica com entradas, decisões, responsáveis, recursos e prazos.
10. Publique apenas artefatos sanitizados e sintéticos, com declaração clara de limitações.

Artefato do portfólio	O que demonstra
Contexto, partes e escopo	Raciocínio e limites da cláusula 4
Método, registro e tratamento de risco	Cláusula 6 e propriedade do risco
Declaração de Aplicabilidade	Decisões de controle rastreáveis
Papel de trabalho de teste	Evidência, amostragem, exceção e conclusão
Pacote de auditoria interna	Programa, plano, critérios, relatório e acompanhamento
Ata de análise crítica	Avaliação e decisões da liderança
Registro de ação corretiva	Causa raiz e eficácia
Memorando de evidência técnica	Alfabetização técnica e limitações

26. Plano de Aprendizagem de Trinta Dias

Um cronograma focado para desenvolver capacidade útil de nível júnior.

Dias	Foco	Entrega
1–5	SGSI, CIA, cláusulas, relação ISO 27001/27002 e escopo	Mapa do SGSI e declaração de escopo
6–10	Critérios, cenários, avaliação, tratamento e aceitação de risco	Registro de riscos e plano de tratamento
11–14	Temas do Anexo A e Declaração de Aplicabilidade	SoA preliminar vinculada a riscos
15–18	Políticas, competência, comunicação, documentos e	Política e procedimento controlados

Dias	Foco	Entrega
19–22	operação Métricas, monitoramento, auditoria e análise crítica	Plano de métricas e programa de auditoria
23–25	Não conformidade, causa raiz, ação corretiva e melhoria	Dois registros de achado e ação corretiva
26–28	Laboratórios autorizados com ferramentas abertas	Dois memorandos de evidência e reteste
29–30	Limpeza do portfólio e prática de entrevista	Pacote final e respostas ensaiadas

Ao final de cada bloco, revise exatidão, rastreabilidade, confidencialidade, autorização e limitações. Corrija lacunas antes de adicionar complexidade.

27. Preparação da entrevista

- Respostas claras, cenários práticos e perguntas para o empregador.*

27.1 O que é um ISMS?

Um sistema de gestão para controlar o risco de segurança da informação através de liderança, planejamento, operação, avaliação e melhoria contínua.

27,2 ISO 27001 versus 27002?

27001 contém requisitos ISMS certificados; 27002 fornece orientação de controle detalhada e não é em si uma norma de certificação.

27.3 O que é o SoA?

Um registro controlado dos controles necessários, a justificativa da inclusão ou exclusão no anexo A e o estado de execução, ligados ao tratamento e às provas.

27.4 Todos os controles do Anexo A são obrigatórios?

A organização deve utilizar o anexo A como verificação de referência e justificar as decisões. Controles necessários seguem tratamento de risco e obrigações; outros controles também podem ser necessários.

27.5 Como se testa um controle?

Defina critérios e escopo, valide a população, amostra por risco, inspecione e reperforme evidências, exceções documentais e correção de reteste.

27.6 O que é uma não conformidade?

Falha em cumprir uma exigência. Requer correção, avaliação, ação adequada e revisão de efetividade.

27.7 O que mudou em 2024?

A alteração exige uma consideração explícita da relevância das alterações climáticas no contexto e observa que as partes interessadas podem ter requisitos relacionados com o clima.

27.8 O que pode um analista júnior concluir com segurança?

Factos estatais apoiados por elementos de prova e âmbito definidos, divulgar limitações e evitar reclamar a autoridade de auditoria ou certificação.

27.9 Perguntas para perguntar ao empregador

- Qual é o escopo ISMS certificado ou pretendido?
- Quem é o dono da aceitação do risco e do SoA?
- Como as populações de evidência são produzidas e validadas?
- Que sistemas gerem riscos, controles, fornecedores, resultados e medidas correctivas?
- Como é mantida a independência do auditor interno?
- Com que equipas técnicas trabalhará este papel?
- Como as conclusões júnior são revistas e treinadas?

28. Modelos, Glossário, Índice e Referências

Estruturas reutilizáveis, termos importantes e pontos de partida autoritários.

28.1 Registro mínimo de risco

Campo	Entrada
ID do risco e proprietário	_____
Objetivo / ativo	_____

Campo	Entrada
Evento de ameaça e condição	_____
Consequência	_____
Controles existentes	_____
Probabilidade e impacto	_____
Risco atual	_____
Tratamento e responsável pela ação	_____
Risco residual e aceitação	_____
Data de revisão	_____

28.2 Papel de trabalho de teste de controle

Campo	Entrada
Critérios e controle	_____
Escopo e período	_____
Proprietário e sistemas	_____
População e verificação de integridade	_____
Amostra e justificativa	_____
Procedimento executado	_____
Evidência inspecionada	_____
Exceções	_____
Conclusão e limitação	_____
Correção e reteste	_____

28.3 Glossário

Termo	Significado
Anexo A	Conjunto de referência de 93 controles de segurança da informação na ISO/IEC 27001:2022.
CIA	Confidencialidade, integridade e disponibilidade.
Conformidade	Atendimento a um requisito.
Controle	Medida que modifica ou mantém o risco.
Ação corretiva	Ação sobre a causa de uma não conformidade para evitar recorrência.
Informação documentada	Informação que a organização deve controlar, manter ou reter.
Parte interessada	Pessoa ou organização que pode afetar, ser afetada ou perceber-se afetada por decisão ou atividade.

Termo	Significado
SGSI	Sistema de gestão de segurança da informação.
Não conformidade	Falha no atendimento a um requisito.
Risco residual	Risco remanescente após o tratamento.
Proprietário do risco	Pessoa ou entidade responsável e autorizada a gerir um risco.
SoA	Declaração de Aplicabilidade.
Alta direção	Pessoa ou grupo que dirige e controla a organização no nível mais alto dentro do escopo.

28.4 Índice de assuntos

Assunto	Capítulo
Controles do Anexo A	13–16
Auditoria	19
Certificação	21
Emenda climática	1, 2, 6, 21
Ação corretiva	12, 20
Evidência	5, 18
Partes interessadas	2, 6
Analista júnior	24–27
Análise crítica pela direção	11, 20
Métricas	11, 18
Ferramentas abertas	22
Avaliação e tratamento de risco	3, 8, 10
Escopo	2, 6
Declaração de Aplicabilidade	4
Fornecedores	13, 18, 23

28.5 Referências oficiais

[ISO/IEC 27001:2022 — visão geral](#)

[ISO/IEC 27001:2022/Amd 1:2024](#)

[ISO/IEC 27002:2022 — visão geral](#)

[Comunicado ISO/IAF sobre mudança climática](#)

[Visão geral de certificação da ISO](#)

[Família ISO/IEC 27000](#)

Lembrete final: Adquira ou acesse legalmente as normas oficiais antes da implementação ou avaliação. Confirme edições, emendas, acreditação, escopo de certificação, requisitos legais, contratos, tecnologia, ameaças e mudanças organizacionais.
